Rapporto finale sull'incidente

Scenario simulato, scritto a partire dalle note sull'incidente del corso. Date, importi e cifre sono quelli dello scenario.

Sintesi

Il 28 dicembre 2022, alle 19:20 PT, l'organizzazione ha confermato che qualcuno aveva avuto accesso non autorizzato ai dati personali e alle informazioni finanziarie dei clienti. Sono stati esposti circa 50.000 record di clienti. Il costo diretto è stimato in 100.000 dollari, senza contare i ricavi che potremmo perdere. L'incidente è stato indagato ed è ora chiuso.

Cronologia

Quando	Cosa è successo
22 dicembre 2022, circa le 15:13 PT	Un dipendente ha ricevuto un'email da un indirizzo esterno. Il mittente diceva di aver rubato dati dei clienti e chiedeva 25.000 dollari in criptovaluta per tenerli riservati. Il dipendente l'ha presa per spam e l'ha cancellata.
28 dicembre 2022	Lo stesso mittente ha scritto di nuovo, questa volta con un campione dei dati rubati e una richiesta di 50.000 dollari. Il dipendente lo ha segnalato al team di sicurezza lo stesso giorno e l'indagine è partita.
Dal 28 al 31 dicembre 2022	Il team di sicurezza ha lavorato per capire come erano stati presi i dati e in quale quantità.

Indagine

Il team di sicurezza è venuto in sede appena è arrivata l'allerta. La causa all'origine era una debolezza dell'applicazione web dell'e-commerce. La pagina di conferma dell'acquisto mostrava un numero d'ordine nell'URL e l'applicazione non verificava che l'ordine appartenesse a chi lo richiedeva. Cambiando il numero, l'attaccante poteva aprire le pagine di conferma di altri clienti. Si chiama forced browsing.

I log di accesso del server web lo hanno confermato. Una sola origine aveva richiesto migliaia di pagine di conferma, un ordine dopo l'altro, a una frequenza che nessun cliente normale raggiungerebbe. È lo schema di uno script che raccoglie dati e corrisponde al campione che l'attaccante ci ha mandato.

Risposta e rimedi

L'organizzazione ha collaborato con l'ufficio comunicazione per informare i clienti coinvolti della violazione, e ha offerto loro servizi gratuiti di protezione dell'identità.

Raccomandazioni

1. Eseguire scansioni delle vulnerabilità e penetration test con regolarità, così un difetto come questo lo troviamo prima noi.

2. Usare l'allowlisting, in modo che l'applicazione serva solo un insieme definito di URL e blocchi automaticamente il resto.

3. Assicurarsi che solo gli utenti autenticati accedano ai contenuti e verificare sul server che ogni ordine appartenga all'utente che lo richiede.

4. Aggiungere un rilevamento per lo schema visto nei log, molte richieste sequenziali da una sola origine, e rallentarlo con un limite di richieste.

5. Dire ai dipendenti di segnalare le email di estorsione, anche quando sembrano spam. Il primo messaggio è arrivato sei giorni prima del secondo e l'indagine poteva partire allora.